

Reflected XSS into HTML Context with Nothing Encoded

Lab

PortSwigger Web Security Academy

Vulnerability

Reflected Cross-Site Scripting (XSS)

Injection Point

Search Bar

Payload Used

```
">z3nsh3ll<svg onload=alert(1)>
```

Description

The application's search functionality was vulnerable to **Reflected XSS**.

First, `z3nsh3ll` was entered into the search bar to identify how the input was reflected by the application.

The input was then modified to include an HTML/SVG payload. The injected SVG element used the `onload` event handler to execute JavaScript.

Proof of Concept

The following payload was entered into the search bar:

```
">z3nsh3ll<svg onload=alert(1)>
```

The successful execution of `alert(1)` confirmed that JavaScript could be injected and executed through the search functionality.

Impact

An attacker could potentially:

- Execute JavaScript in a victim's browser
- Modify webpage content
- Perform actions in the context of the vulnerable application
- Access data available to JavaScript under the application's origin

Root Cause

User-controlled search input was reflected into the application's HTML without proper output encoding.

Remediation

- Apply proper HTML output encoding
- Validate and sanitize user-controlled input
- Avoid inserting untrusted input directly into HTML
- Implement an appropriate Content Security Policy (CSP)

Classification

CWE: CWE-79 — Improper Neutralization of Input During Web Page Generation

OWASP: Cross-Site Scripting (XSS)

Type: Reflected XSS

Injection Point: Search Bar

Evidence

No screenshots were captured during the lab. The vulnerability was confirmed through successful execution of the injected `alert(1)` payload.

Status

Lab Solved

Platform: PortSwigger Web Security Academy

